c2blue55 — real-time DNS command-and-control detection with observable evidence

Hackers-Arise contest entry · executive summary · hazyhaar lab · 2026-11-06

Video (silent, 5 min 48 s, subtitled): https://github.com/hazyhaar/c2blue55/blob/main/hackers-arise-2026/c2blue55-demo-en-v2.mp4
Detection engine repository (MIT): https://github.com/hazyhaar/c2blue55 — includes the comparative benchmark of 7 open-source DNS security stacks (`docs/dns_detection_solutions_benchmark.md`)
Demonstration kit (dashboard `c2blue-dns-live`, replay scripts, the 20 real captures): https://github.com/hazyhaar/c2blue55/tree/main/hackers-arise-2026

The red-team generator (redbench) and the scenario script that drives it are not published: the matrix, mixed-flow and load figures below come from that private generator and are documented in the evidence files; the real-capture replay and the dashboard are fully reproducible from the public code.

1. What the entry is

c2blue55 is a Go 1.27 detection engine for DNS tunnelling and command-and-control (C2). In this entry it runs as `c2blue-dns-live`: a UDP listener that classifies every datagram it receives, answers it, and shows the verdict in a dashboard with the reason, the thresholds that fired, the benign guards that were evaluated and the SHA-256 of the datagram. **redbench** is the red-team side: a generator that opens a real UDP socket, registers its source IP:port with c2blue55, then emits either legitimate DNS noise or one of 19 hostile patterns. **po2po** is the front office that presents both sides.

The governing rule is that the generator describes what it sends but **c2blue55 judges only the bytes it receives**: the campaign identifier (`run_id`) travels in the HTTP control plane, never inside a query name, and never becomes a detection criterion. Two permanent checks prove it: a benign query sent under a hostile campaign stays benign, and elongated labels sent under a benign campaign alert.

Everything below was executed on 2026-11-05 and 2026-11-06 on a local laboratory and recorded live; waits were shortened in the video, nothing was re-ordered or re-typed. No public deployment is claimed.

2. Results at a glance

Item	Result actually executed
Real offensive tools	7 tools (dnstt, iodine, dns2tcp, Slipstream, VayDNS, NoizDNS, Soar), 18 fresh captures recorded by tcpdump on a private mesh, **18/18 detected** on offline replay through the same classifier; application transfers proven (35,149-byte HTTP resource with identical SHA-256 at both ends for dnstt and dns2tcp, three 1,024-byte ICMP echoes for iodine).
Negative control	200 real queries and 200 NOERROR answers across 200 distinct apexes: **0 alert on 400 observations**. The same 400 observations on a single apex: 136 burst alerts (M-03). Raw request rate alone is not treated as C2 evidence.
Functional matrix	**26/26**: 7 legitimate traffic families without alert, 19 hostile patterns each matched to its expected reason code; first alert between 0 ms and 145 ms after the first question.
Mixed flow	1,000 queries in one run, 80 % legitimate noise and 20 % elongated labels: 800 classified benign, 200 classified M-01, **0 alert on the benign share**.
Sustained load	10,000 configured QPS for 5 s: 48,783 sent, 48,783 received, 0 lost, 0 C2 alert, 81 % of one core.
Saturation	45,000 configured QPS for 5 s: 205,771 sent, 102,232 received, **103,539 losses counted and displayed**, 0 C2 alert, 97 % of one core.
Evidence	Per run: JSONL events with per-datagram SHA-256, reconstructed PCAP, manifest with a retain-all policy; files in mode 0600.
Software verification	Race-enabled test suites: 41 tests on the dashboard packages, 80 on the generator and front office, 0 failure (count=3 in the earlier campaign: 123 and 240 pass actions).

3. How a verdict explains itself

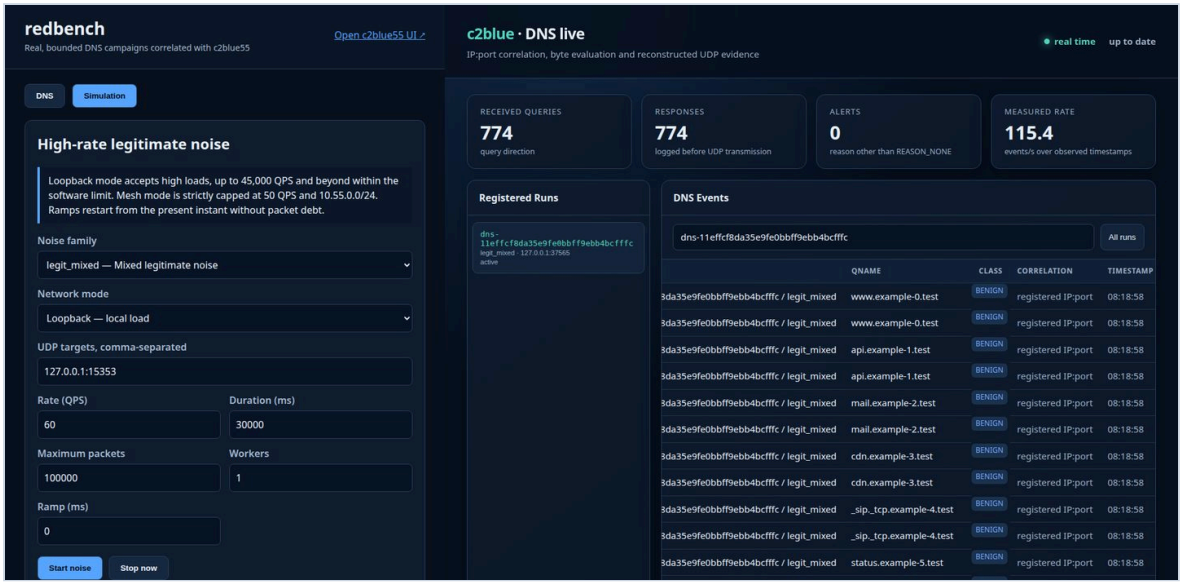


Figure 1 — Left: redbench emitting legitimate mixed noise at 60 QPS from a registered socket. Right: c2blue55 filtered on the same `run_id`; queries and responses carry the real source IP:port, alerts stay at 0.

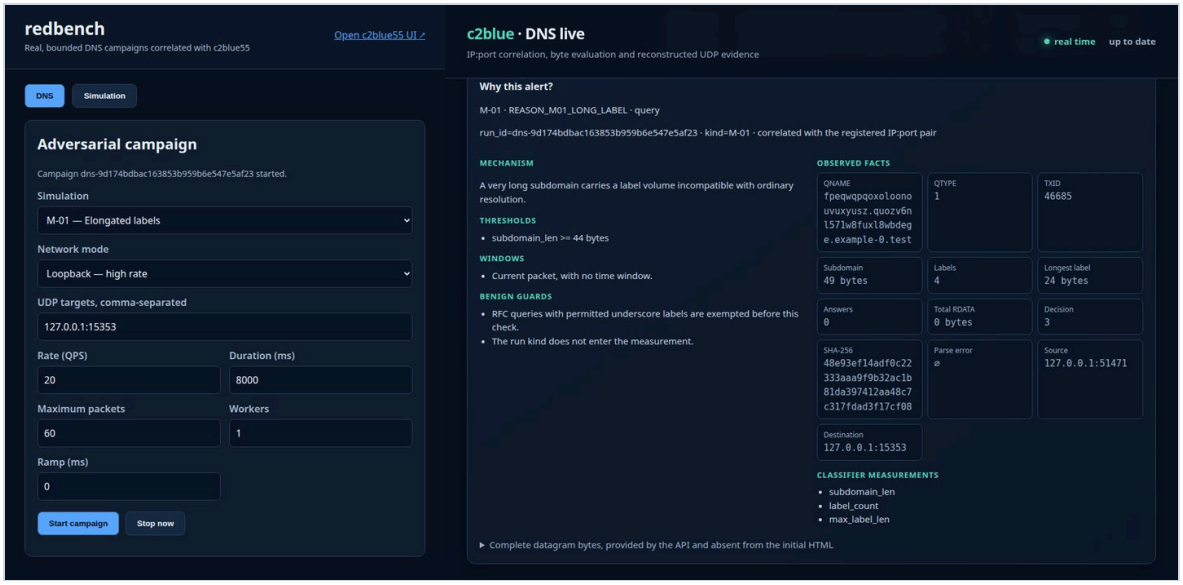


Figure 2 — “Why this alert” for an M-01 query: mechanism, real threshold (subdomain ≥ 44 bytes), window, benign guards (RFC underscore labels exempted; the run kind never enters the measurement), observed facts, datagram SHA-256, and the complete bytes on demand.

4. Evidence from real offensive tools

Seven real DNS tunnelling tools were run between two hosts of a private WireGuard mesh with no external target. Every capture was recorded independently by tcpdump on the server side, then replayed offline through `c2agent replay`. Digests of the capture files match the benchmark summary; failed attempts (iodine HTTP forwarding, Slipstream multipath without a common connection identifier) are kept in the evidence rather than edited out.

Tool	Runs	Observations	Reasons observed in the fresh replay
dns2tcp	1	282	P1 downlink exfiltration 271, M-01 long label 4, P15 RDATA renewal 1
dnstt	1	196	P1 139, M-01 22, M-02 high entropy 22, P15 5
iodine	1	240	M-01 60, P1 7, M-02 2
NoizDNS	4	316	M-01 144, M-02 72, P1 24, P15 11
Slipstream	3	396	M-01 324, P15 47, P1 25
Soar	2	194	P1 92, M-01 39, P15 39, M-02 15, P14 NXDOMAIN answer payload 2
VayDNS	6	1,292	M-01 360, P1 301, P15 178, P7 SRV C2 98
Benign, distributed	1	400	none (200 apexes, real `dig` queries, no threshold changed)
Benign, single apex	1	400	M-03 high-frequency burst 136

5. Criteria instead of labels

The table reflects the controls the classifier actually applies; the dashboard shows the measured values next to each verdict. Internal measurements that are not exported are identified as such and never receive invented values.

Pattern	Measurement and threshold applied	Guard or window
M-01	Subdomain length ≥ 44 bytes.	Current packet; run kind ignored.
M-02	First label ≥ 20 bytes, entropy ≥ 4.10 bits/byte, cardinality > 16.	P2, P12 and M-01 evaluated first.
M-03	At least 15 queries to one apex within ≤ 2 seconds.	Responses excluded; pipeline per run.
M-04	Consonant run ≥ 5, RCODE = 3, at least 4 distinct QNAMEs.	At most 16 fingerprints.
P1	RDATA ≥ 180 bytes in TXT/NULL, or ratio > 2 and entropy > 4.	RFC TXT prefixes exempted.
P3	At least 5 QTYPEs, CV < 0.12, Markov entropy > 0.40.	8 queries; A/AAAA merging ≤ 50 ms.
P4	Subdomain of 10 to 32 bytes across at least 4 parents.	Dot, hyphen and underscore excluded.
P20 / P21	3 distinct SOA fingerprints / 8 distinct full-width IPv6 interface identifiers.	10-minute / 600-second windows.

6. Reproduce it

```
# Go 1.27 with GOEXPERIMENT=simd
go build -o bin/c2blue-dns-live ./cmd/c2blue-dns-live
go build -o bin/c2agent ./cmd/c2agent
(umask 077; head -c 32 /dev/urandom | base64 | tr -d '/+=\n' > ui-token)
export C2BLUE_DASHBOARD_TOKEN="$(cat ui-token)"
bin/c2blue-dns-live -udp-listen 127.0.0.1:15353 -http-listen 127.0.0.1:4256 -evidence-dir evidence &
# offline replay of the 20 real captures through the same classifier, with digest check
python3 replay-benchmark.py captures replay
# or any single capture
bin/c2agent replay --pcap captures/dnstt-clear.pcap --out-root replay --dns-ports 53
# evidence of a dashboard run: manifest, JSONL events with per-datagram SHA-256, reconstructed PCAP
curl -s -u evaluator:"$(cat ui-token)" http://127.0.0.1:4256/api/v1/evidence/<run_id>
```

The dashboard runs on loopback, token-protected; nothing needs to be exposed. Any DNS client aimed at the listener (for example `dig @127.0.0.1 -p 15353`) appears in the dashboard with its verdict. The 26-case matrix, the mixed flow and the load stages were driven by the private generator through both HTTP APIs; their reports (`full-report.json`, `load-10k.json`, `load-45k.json`) are API-driven syntheses, not independent measurements. The offline replay of kernel captures is the independent one, and it is the part a third party can rerun in full.

7. Limits that stay visible

- **Scope of the synthetic matrix:** M-01..M-04, P1..P13, P20, P21. P14 and P15 are exercised only by the real captures (Soar, dnstt, VayDNS…), not by the generator.
- **Capture modes:** the dashboard PCAP is an Ethernet/IP/UDP reconstruction of processed datagrams (manifest field `capture_mode = udp-reconstructed`); only the benchmark PCAPs are kernel captures.
- **Saturation:** at 45,000 configured QPS the single-core path no longer answers every query; losses are counted, the memory window evicts old events (counter exposed), on-disk evidence is not reduced.
- **Network:** interactive part on IPv4 loopback; tool captures from a private mesh; no public target, no public deployment. Remote evaluator access would need TLS and secret management.
- **Known open boundaries:** Slipstream multipath across resolvers, short NoizDNS exchanges, a tunnel multiplexed inside a shared HTTP/3 connection. A host-log normality baseline exists but does not generalise yet (its cold-day holdout flags every event) and is not part of this entry.
- **Self-audit:** the comparative benchmark in the repository applies the same standard to c2blue55 and documents its own false-positive boundaries (uncalibrated foreign zones, multi-domain browsing) alongside 24 disclosures to the other six stacks, 20 of them as live GitHub issues.

Lexicon

run_id — campaign identifier exchanged over HTTP, never in DNS. **M-xx / Pxx** — pattern families: M = lexical or burst measurements on single packets or short windows, P = stateful protocol grammar rules. **Reason code** — the single named rule that fired, e.g. `REASON_M01_LONG_LABEL`; `REASON_NONE` means benign. **Evidence manifest** — JSON listing the JSONL and PCAP of a run and its retention policy. **c2agent replay** — offline execution of the classifier on a PCAP, producing observations, states and a signed manifest. **Apex** — the registrable parent domain under which subdomains are counted.